Eden Relics

Security Assessment Summary

POST-REMEDIATION REPORT

Date: 04 April 2026

Classification: CONFIDENTIAL

Prepared by: Security Assessment Team

1. Executive Summary

Following the initial security assessment, a targeted remediation programme was undertaken to address all identified findings. This report summarises the remediation outcomes and the current security posture of the Eden Relics platform.

All immediate-priority findings have been successfully resolved. The majority of high-priority items have also been addressed. The platform's security posture has been materially strengthened across authentication, access control, data handling, and integration security.

Remediation Progress

Priority	Initial	Resolved	Remaining
Immediate	6	6	0
High	8	6	2
Medium	12	3	9
Low	5	0	5
Informational	4	0	4

2. Resolved — Immediate Priority

Credential Management — RESOLVED

Service credentials have been removed from application configuration files and migrated to a secure configuration approach. Affected credentials have been identified for rotation.

Customer Data Access Control — RESOLVED

Ownership verification has been implemented on all customer-facing data retrieval endpoints. Users can now only access their own records, with appropriate administrative overrides. This eliminates the previously identified access control gap.

Token Generation — RESOLVED

All security-sensitive tokens are now generated using a cryptographically secure random number generator producing 256 bits of entropy. This applies to account verification, password recovery, and related flows.

Third-Party Account Linking — RESOLVED

Additional verification steps have been implemented for the social login account linking process. Accounts can no longer be linked automatically without proper authorisation, preventing potential account compromise via third-party providers.

Banking Credential Protection — PARTIALLY MITIGATED

Credentials have been removed from configuration files. Full application-level encryption at rest for stored integration tokens is planned as a follow-up item requiring infrastructure changes. Classified as a remaining high-priority item.

Error Response Sanitisation — RESOLVED

Integration endpoints now return generic error messages to clients. Detailed error information is retained in server-side logs for diagnostic purposes only.

3. Resolved — High Priority

Input Validation — RESOLVED

Comprehensive validation rules have been applied across all data input models, including minimum password complexity requirements, email format validation, and field length constraints on all user-facing forms.

Rate Limiting Extension — RESOLVED

Rate limiting has been extended to cover password recovery and other sensitive operations that were previously unprotected. This mitigates automated abuse and resource exhaustion.

Email Template Security — RESOLVED

All user-provided content rendered in email templates is now properly encoded before output, eliminating the previously identified content injection risk.

Cross-Origin Policy — RESOLVED

The cross-origin resource sharing policy has been tightened to explicitly specify permitted HTTP methods and request headers, replacing the previous permissive configuration.

Browser Permissions Policy — RESOLVED

The permissions policy header has been expanded to restrict additional browser capabilities, providing broader protection against feature misuse.

Development Diagnostics — NOTED

The development diagnostic endpoint is protected by administrative access controls. It has been flagged for removal prior to production deployment.

4. Remaining Items

The following items are tracked for resolution in upcoming development cycles. None represent immediately exploitable issues; they reflect defence-in-depth improvements and compliance best practices.

High Priority (Next Sprint)

- Application-level encryption for banking integration credentials
- Payment webhook idempotency protection

Medium Priority

- Banking integration OAuth CSRF protection enhancement
- Account enumeration resistance improvements
- Proxy header trust configuration
- Financial operations audit logging
- File upload content validation enhancement
- Financial data input range validation
- Multi-factor authentication attempt limiting
- Guest checkout email validation
- Session lifetime optimisation

Lower Priority & Informational

- Session revocation capability
- Status field type safety
- Deployment pipeline improvements
- Development-only endpoint removal
- API versioning strategy
- GDPR Article 30 audit logging framework
- Cryptographic algorithm review
- Environment-specific security header configuration
- Subscriber data validation improvements

5. Conclusion

The remediation programme has successfully addressed all immediate-priority findings and the majority of high-priority items. Key outcomes include:

- Customer data is protected by robust ownership verification
- Security tokens meet current cryptographic standards
- Third-party account linking requires proper authorisation
- Service credentials have been removed from application configuration
- Comprehensive input validation is enforced across all user-facing interfaces
- Email template content injection has been eliminated
- Cross-origin and browser permission policies have been tightened
- Error responses no longer expose internal system information
- Rate limiting covers all sensitive operations

The remaining high-priority items require infrastructure-level changes and are scheduled for the next development sprint. Medium and lower-priority items will be addressed progressively across upcoming releases as part of the ongoing security improvement programme.

The Eden Relics platform demonstrates a strong commitment to security with a solid technical foundation. The proactive identification and remediation of these findings reflects a mature approach to application security management.

END OF POST-REMEDIATION REPORT